Institute of Technology of Cambodia
Faculty of Electrical Engineering
Génie Informatique et Communication

GICI5CC · CLOUD COMPUTING · WEEK 10

Security in the Cloud

Access control, the layers of security, the shared responsibility model and AWS IAM.



Heng Rathpisey · Department GIC · Academic year 2025–2026

Recap

LAST SESSION

Serverless computing, microservices

Loosely coupled services built without managing servers.

LAST SESSION

AWS Lambda

The serverless compute service on AWS.

Learning objectives

1. Describe security fundamental concepts.
2. Explain AWS IAM features, benefits and use cases.

THIS WEEK

Security

Access controls, the layers of datacenter security, and the AWS shared responsibility model.

Introduction to security



Security is a primary need for datacenters, on-premises or in the cloud: access control, security layers and the shared responsibility model.

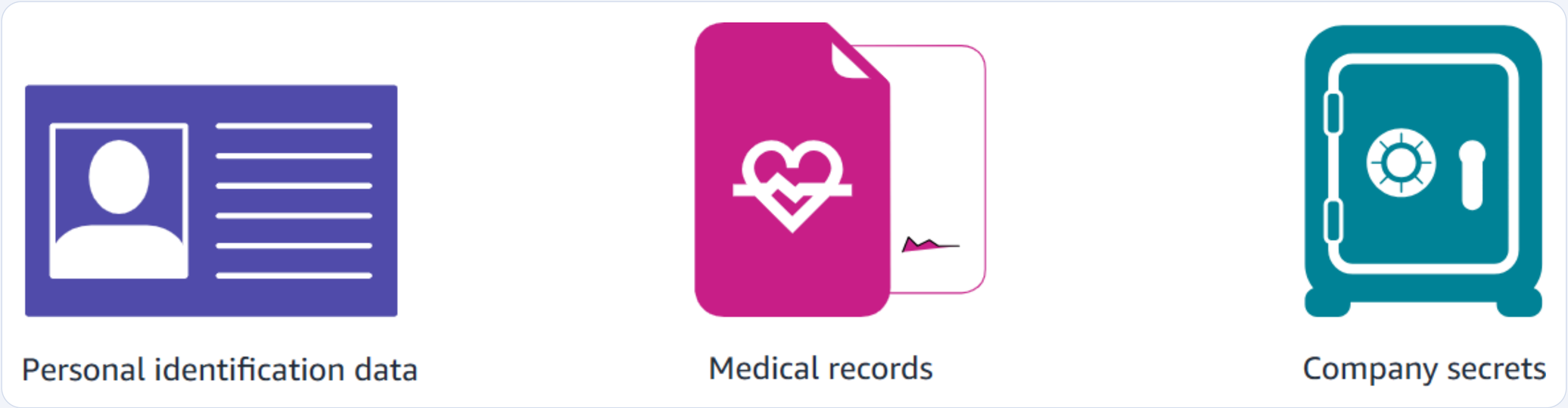
PART 1

Access control

Who can reach the data, and what they are allowed to do with it.

Week 10

IT security

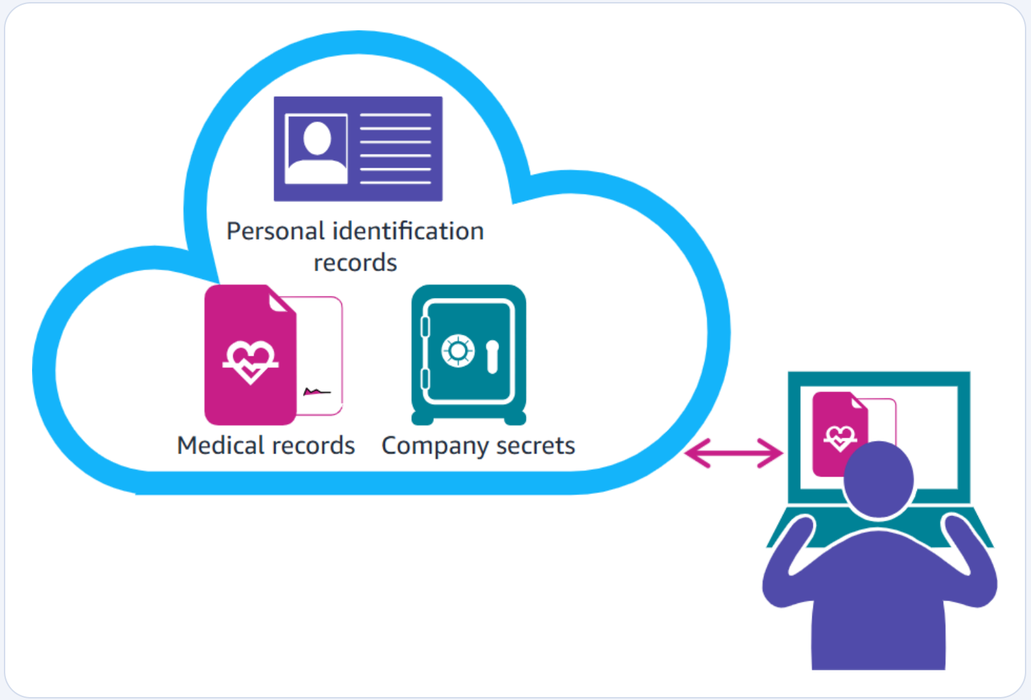


IT security is a top priority for everyone. A large corporation or a single user on social media both have data to protect.

IT security: who needs access

Protecting this kind of data can get complicated, because certain users often need to have access to it.

Their access might be long term or short term, depending on their role and the relevance of the data to their role.

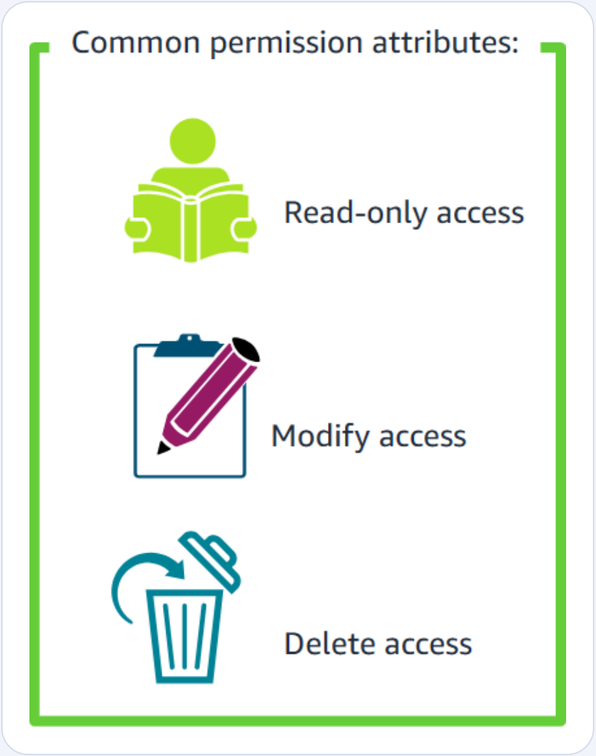


IT security: permissions

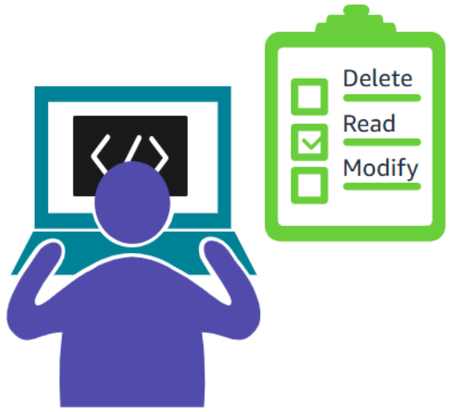
Permissions define the type of access a user has to the data. They also depend on the user's role.

Common user permissions include read only, modify and delete.

If a user only needs to retrieve information, grant read-only access. This prevents the data from being edited or deleted, accidentally or maliciously.

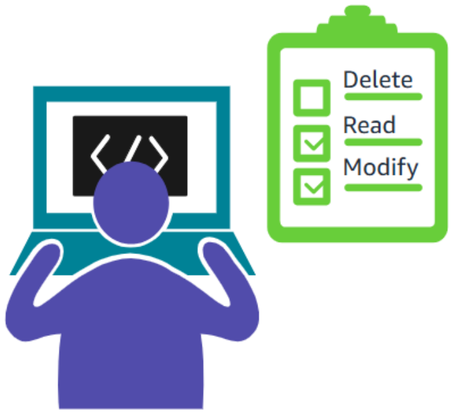


IT security: an example



Quality control associate

Tests the application: read only



Application developer

Writes the application: read and modify

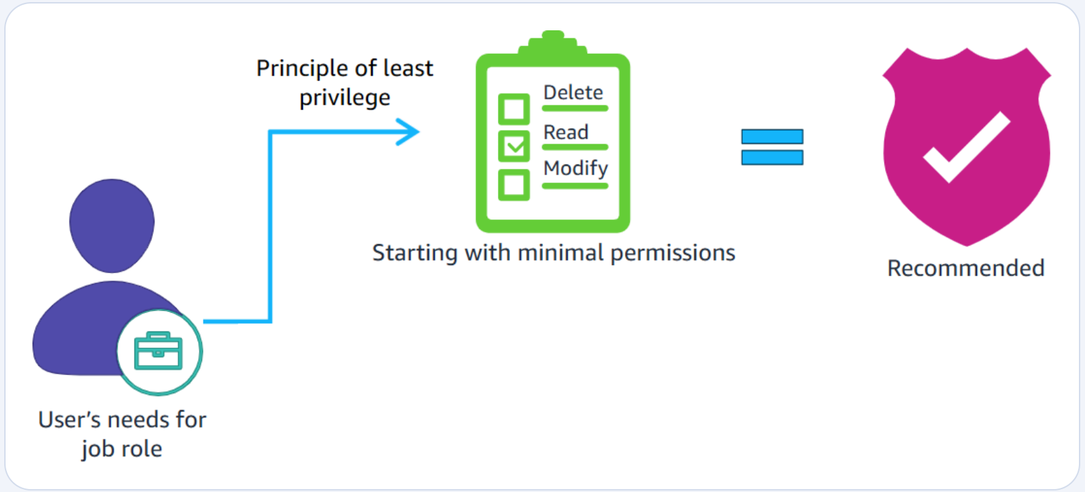
Permissions play an important role in giving each associate the proper access.

Principle of least privilege

Grant only the *minimal privileges* a user needs.

First determine what users need to be able to do. Then create permissions that let them perform only those tasks.

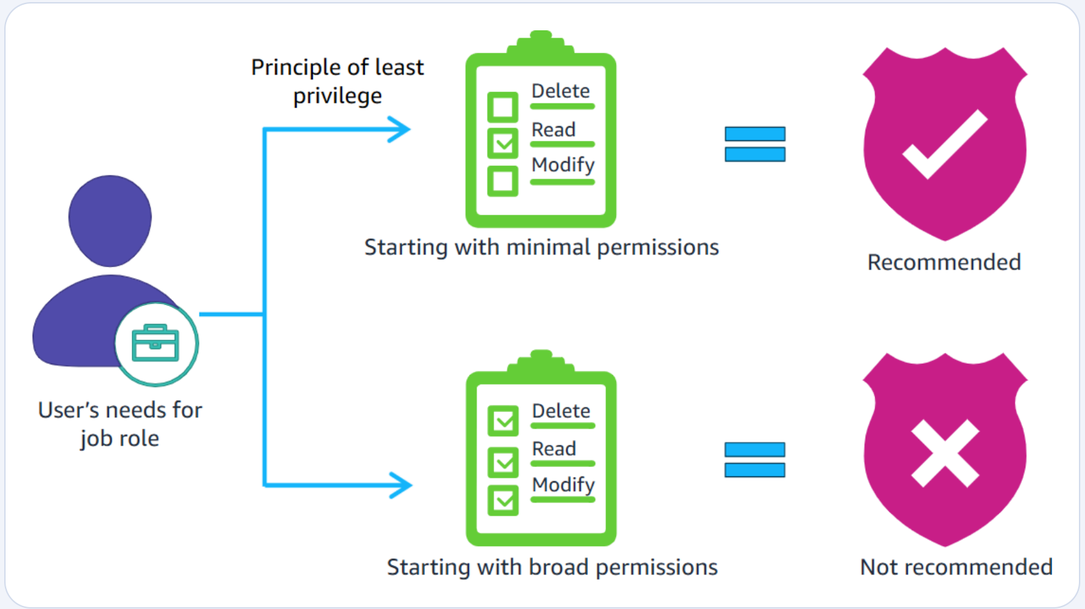
Start with a minimum set of permissions, and grant additional permissions as necessary.



Least privilege: start small

Starting with minimal permissions is more secure than starting with permissions that are too broad.

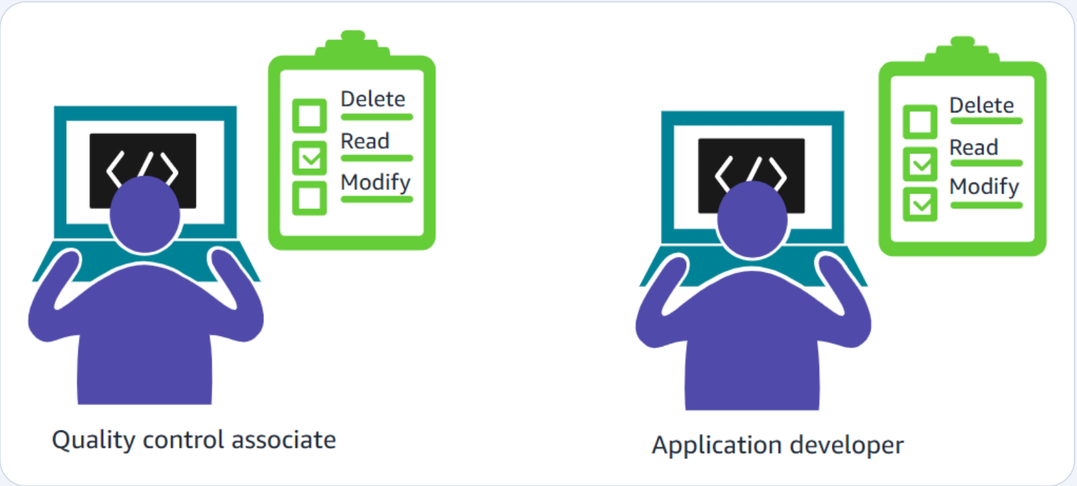
Trying to lock down broad permissions later, after they have been granted, is harder and riskier.



Least privilege: grow when needed

The quality control associate and the application developer had different permissions.

If the quality control associate is required to make inline notes in the code, their permissions can be updated to modify access.



Least privilege: not every role

Suppose both report to a people manager with no IT skills, who cannot read code.

The manager should not be given access to the code files, because it is irrelevant to their job functions.

Only give a user permissions that align with the needs of their job role.

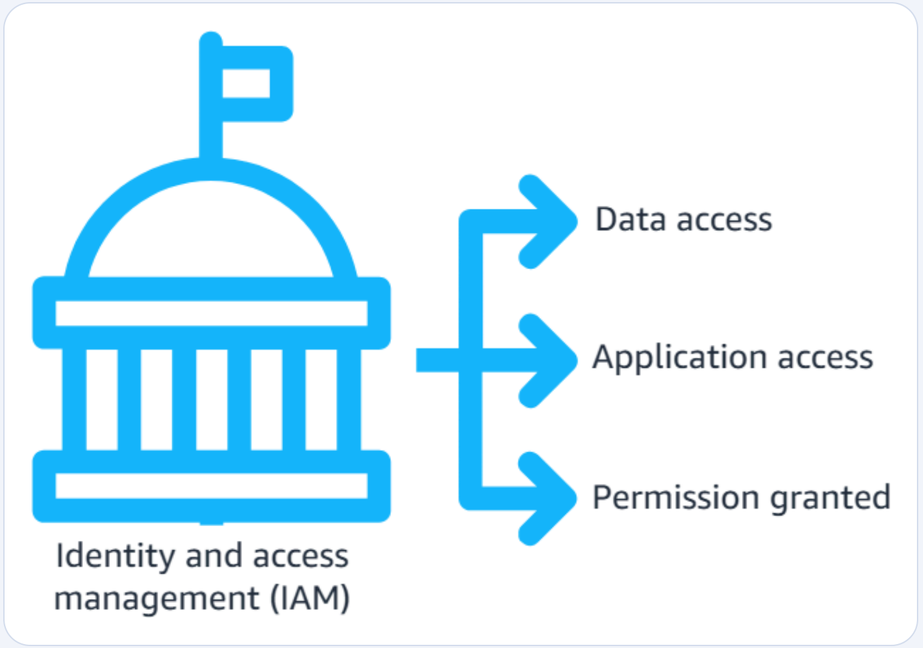


Identity and access management

Organizations can have thousands of users that require different levels of permissions to various data sources.

This needs to be managed carefully. An organization should use an identity and access management tool to govern which users can access its data and applications.

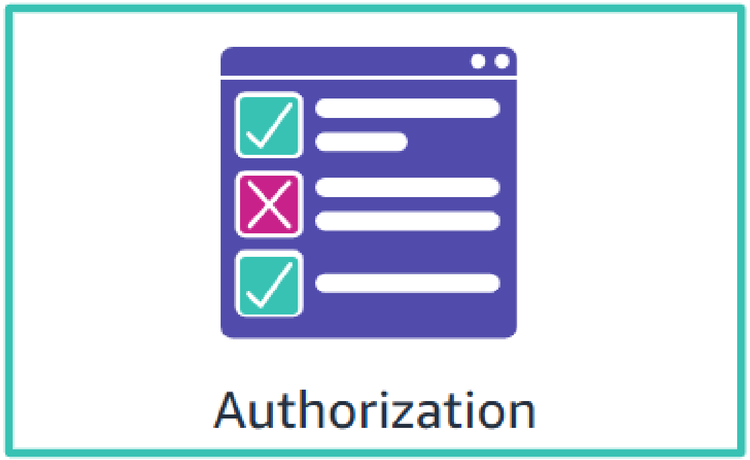
This is also how permissions for the data and applications are managed.



Authentication and authorization



Prove who you are



Decide what you may do

These are the foundational processes that identity and access management relies on.

Authentication, then authorization

FIRST

Authentication

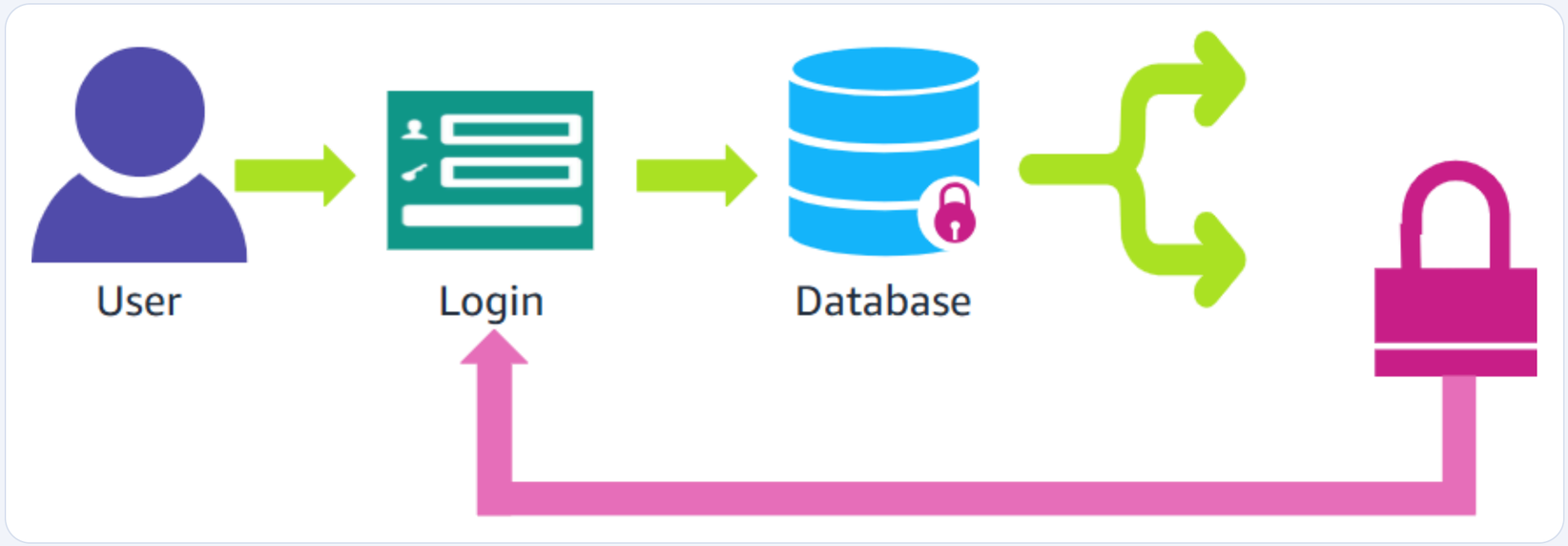
A user or system must first prove their identity. At the airport, you present identification to the security official before you can enter a restricted area. A similar concept applies for gaining access to IT resources.

SECOND

Authorization

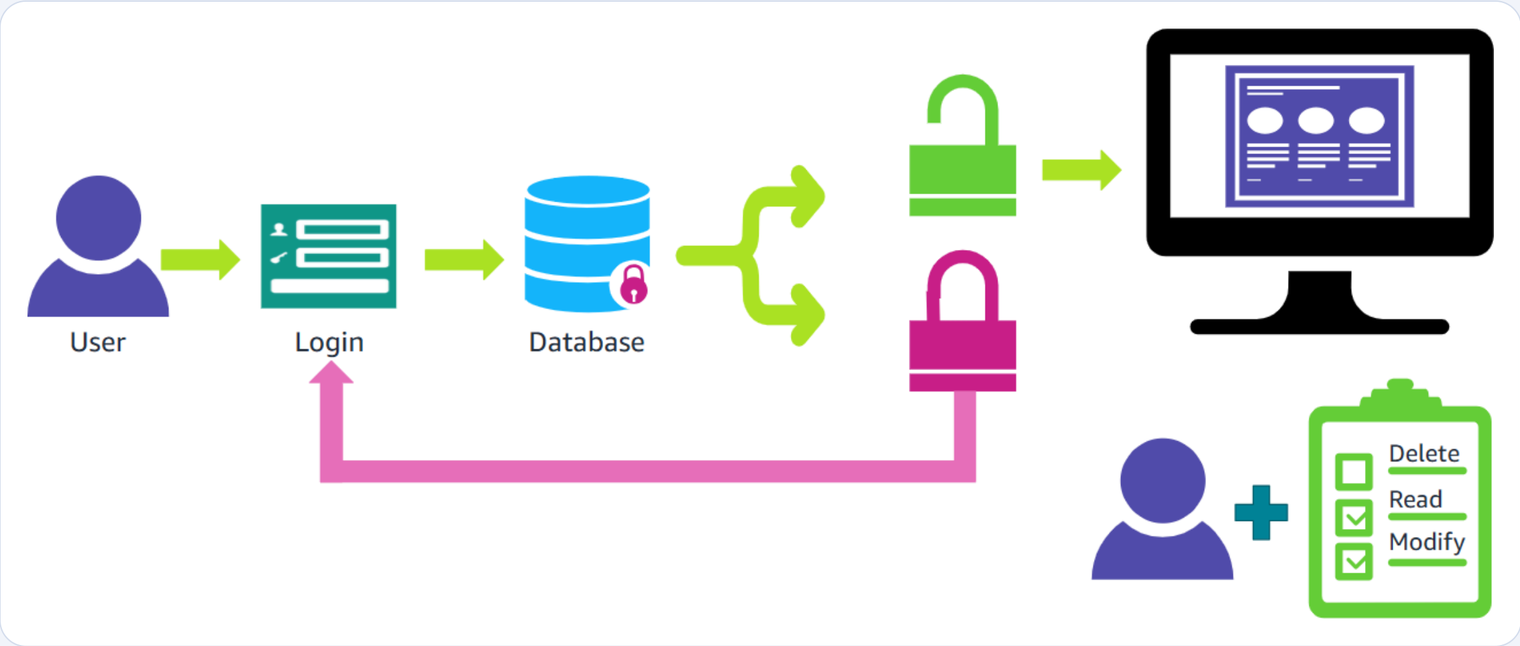
The process of determining what permissions a user should be granted. After a user has been authenticated, they must be authorized to access the IT resource or data that they are requesting.

Authentication in action



The username and password are checked against a database. If they do not match, the user can try again. Some applications limit failed attempts.

Authorization in action



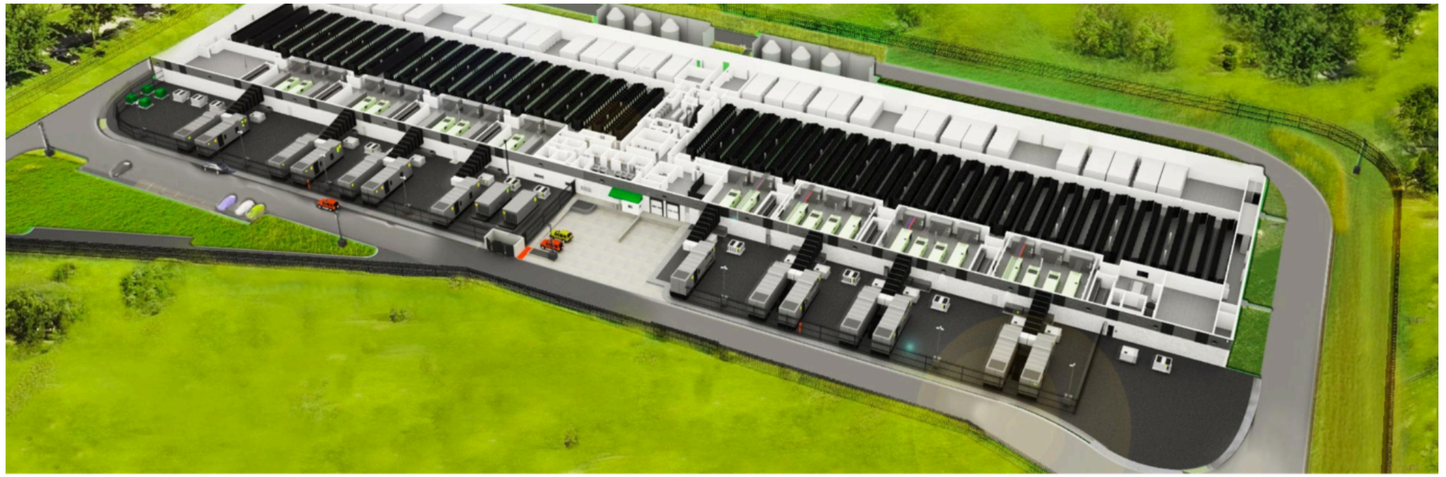
If they match, the user gains access. Authorization then determines the permissions for that authenticated identity.

PART 2

Layers of security

IT security starts with protecting the physical datacenter, then the data files themselves.

Layers of security



AWS data center

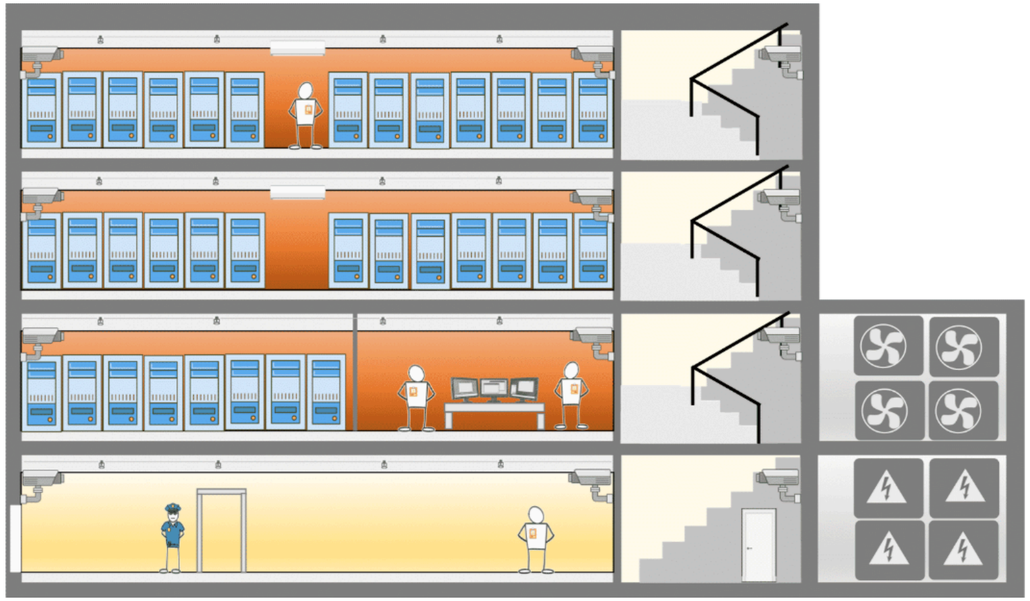
- Perimeter layer
- Environment layer
- Infrastructure layer
- Data layer

The four main layers: perimeter, environmental, infrastructure and data. We use an AWS datacenter as the model.

Perimeter layer

AWS datacenter physical security begins at the perimeter layer.

It includes security features that can vary by location, such as security guards, fencing, security feeds, intrusion detection technology and other security measures.



Perimeter layer: four measures

Building

AWS datacenters are housed in nondescript, undisclosed facilities, protected by guards, fencing, security feeds and other measures.

Surveillance

Professional security staff use video surveillance, intrusion detection and access log monitoring. Entrances sound alarms if a door is forced or held open.

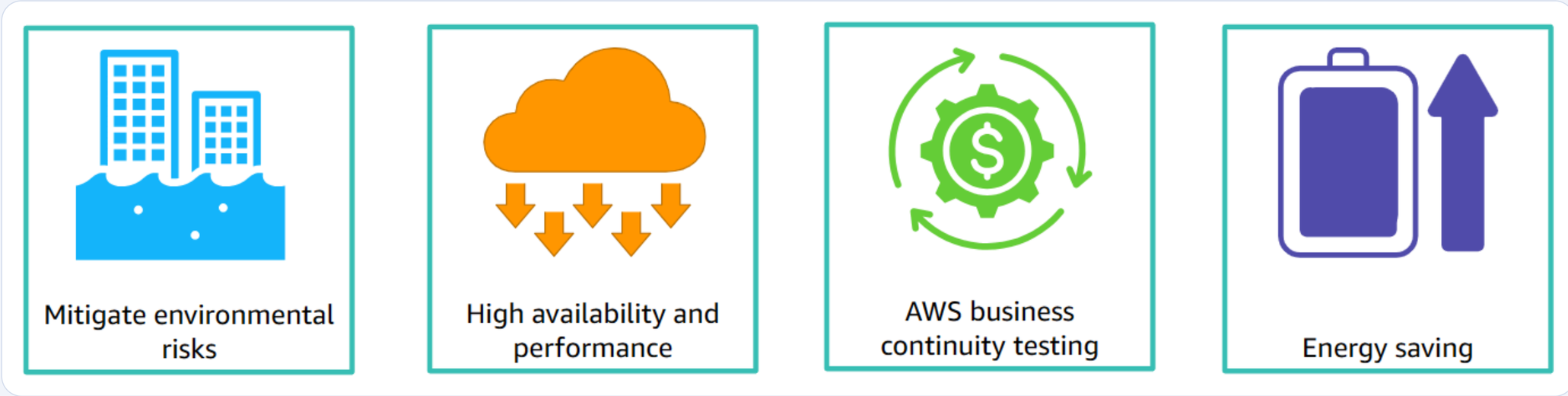
Employee scrutinization

Only AWS employees who routinely need access are given permissions to relevant areas. Others go through the visitor process with an escort.

Principle of least privilege

AWS limits access to pre-approved areas, and only for employees and contractors with a legitimate business need.

Environmental layer

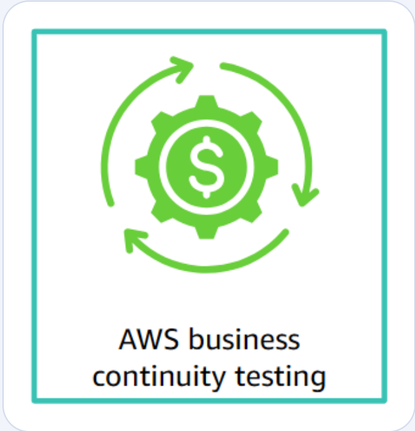


Dedicated to environmental considerations, from site selection and construction to operations and sustainability.

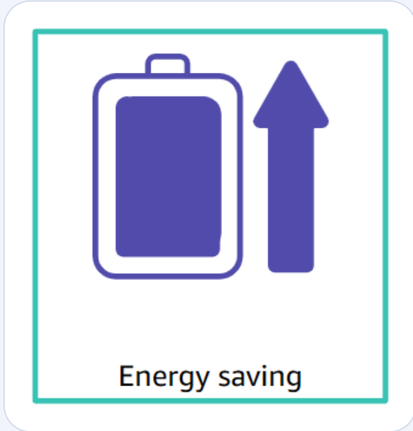
Environmental layer in practice



AWS carefully chooses datacenter locations to mitigate environmental risks like flooding, extreme weather and seismic activity.

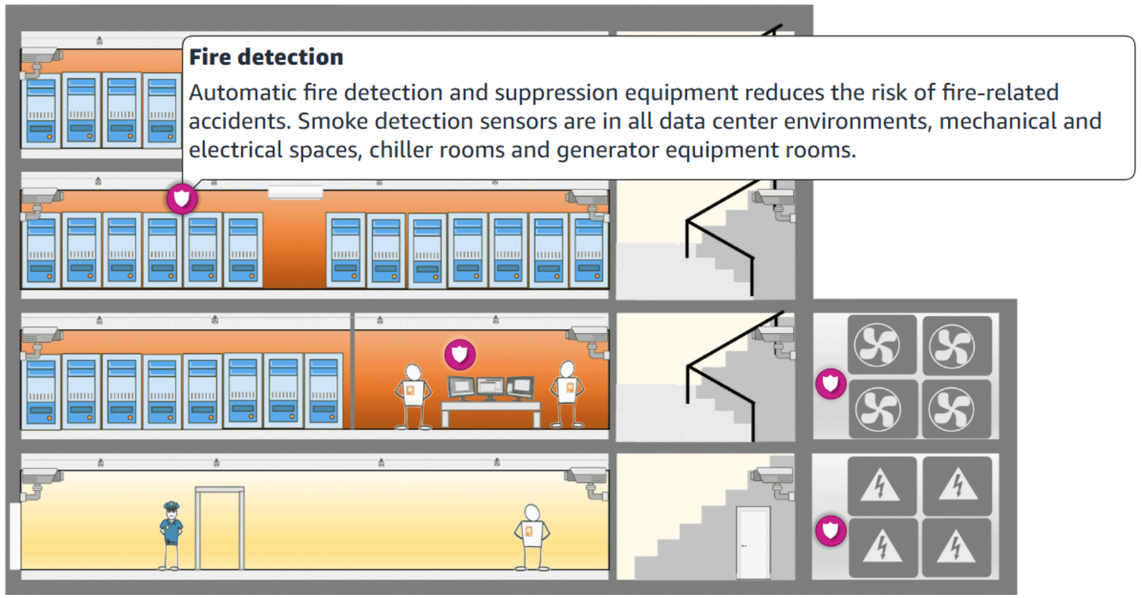


To prepare for the unexpected, AWS tests its business continuity plan regularly, with drills that simulate different scenarios.



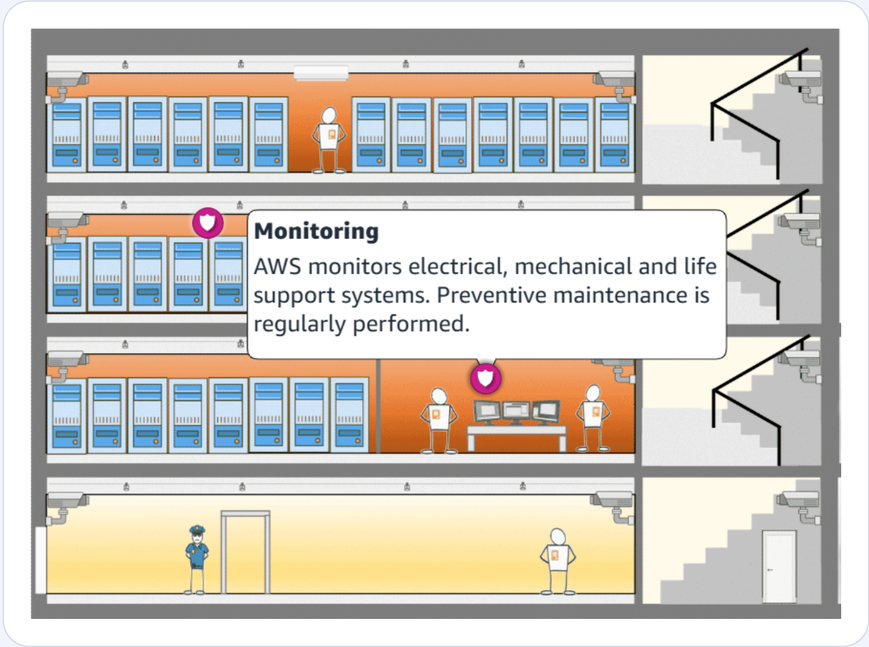
Companies generally use 77% fewer servers and 84% less power in the AWS Cloud than in their own datacenters, with a 28% cleaner mix of solar and wind power.

Infrastructure layer: fire detection



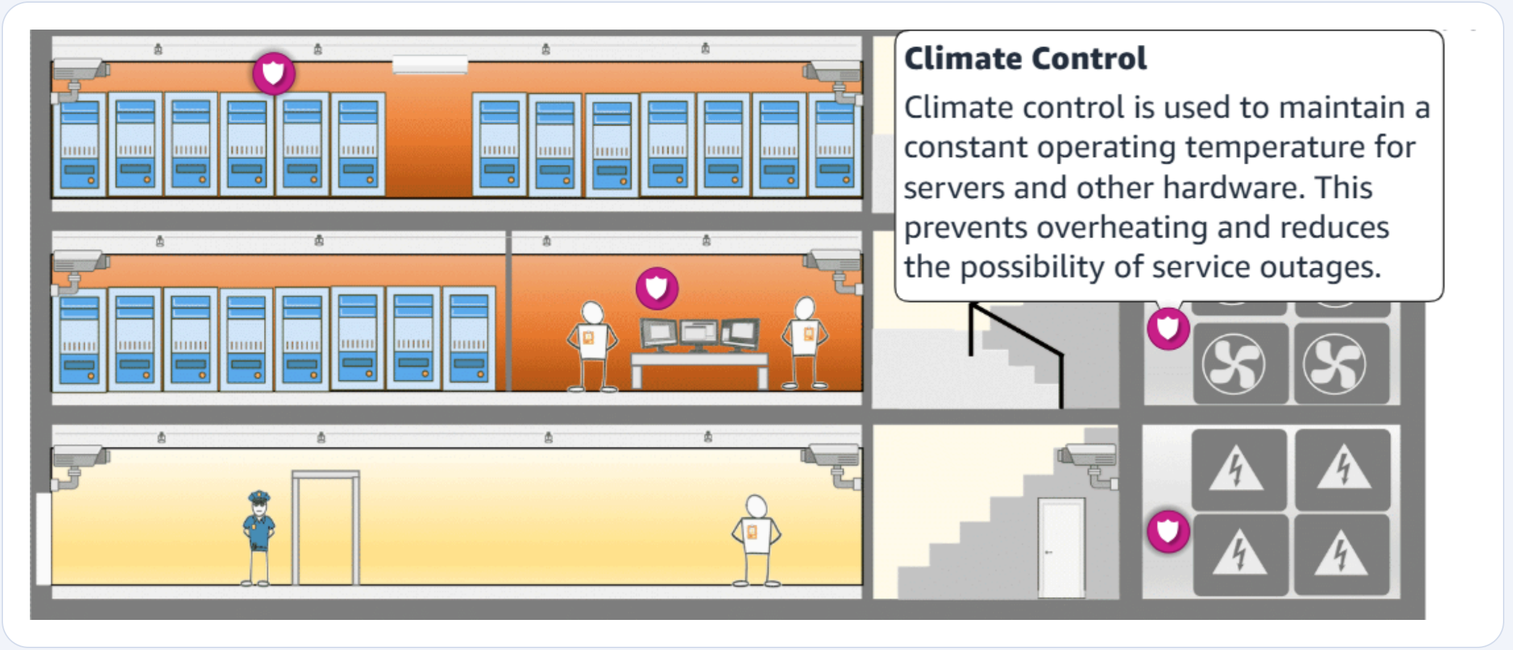
Automatic fire detection and suppression equipment reduces the risk of fire. Smoke sensors are in every datacenter, mechanical and electrical space.

Infrastructure layer: monitoring



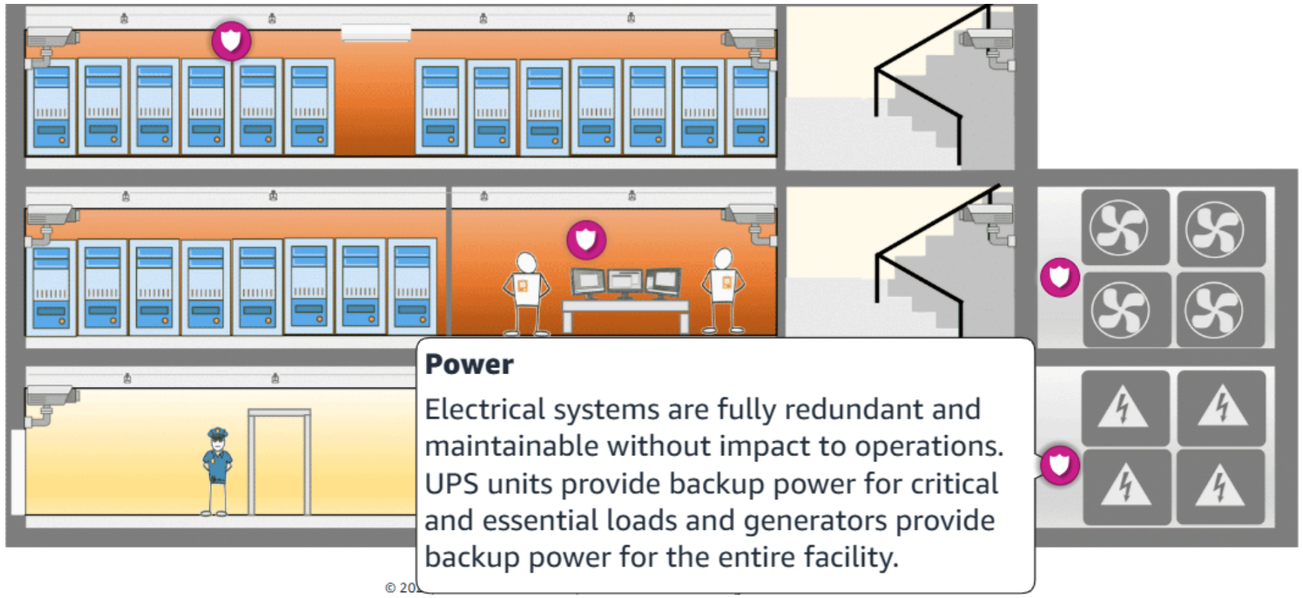
AWS monitors electrical, mechanical and life support systems. Preventive maintenance is regularly performed.

Infrastructure layer: climate control



Climate control keeps a constant operating temperature for servers and hardware, preventing overheating and reducing the possibility of outages.

Infrastructure layer: power



Electrical systems are fully redundant. UPS units back up critical loads, and generators provide backup power for the entire facility.

Data layer



Decommissioning

Storage devices are decommissioned using the National Institute of Standards and Technology techniques to destroy customer data.

Audits

AWS is audited by external auditors to confirm that the established rules needed to obtain security certifications are followed.

Breach response

AWS servers can notify employees of any attempts to remove data. In the unlikely event of a breach, the server is automatically disabled.

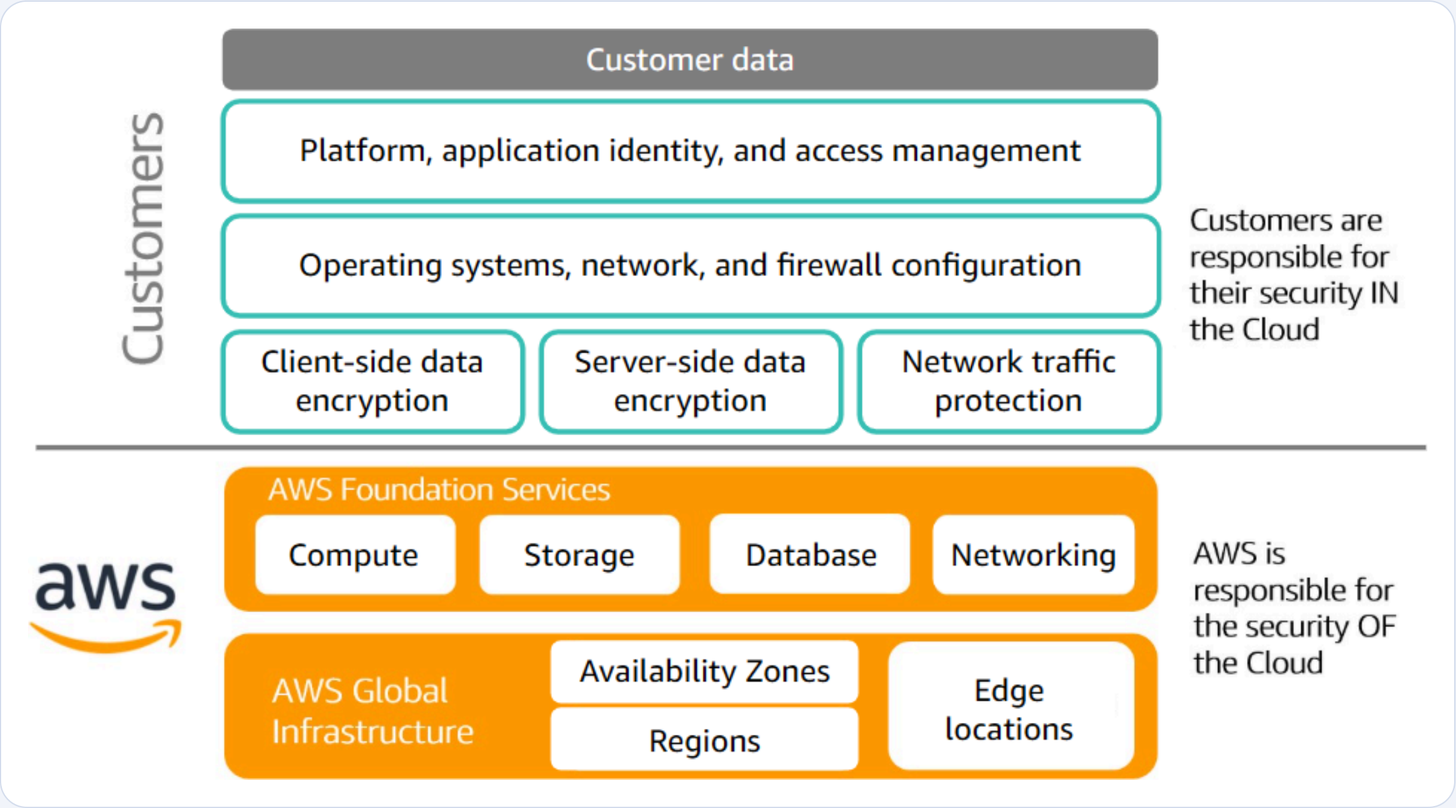
Source: AWS, NIST

PART 3

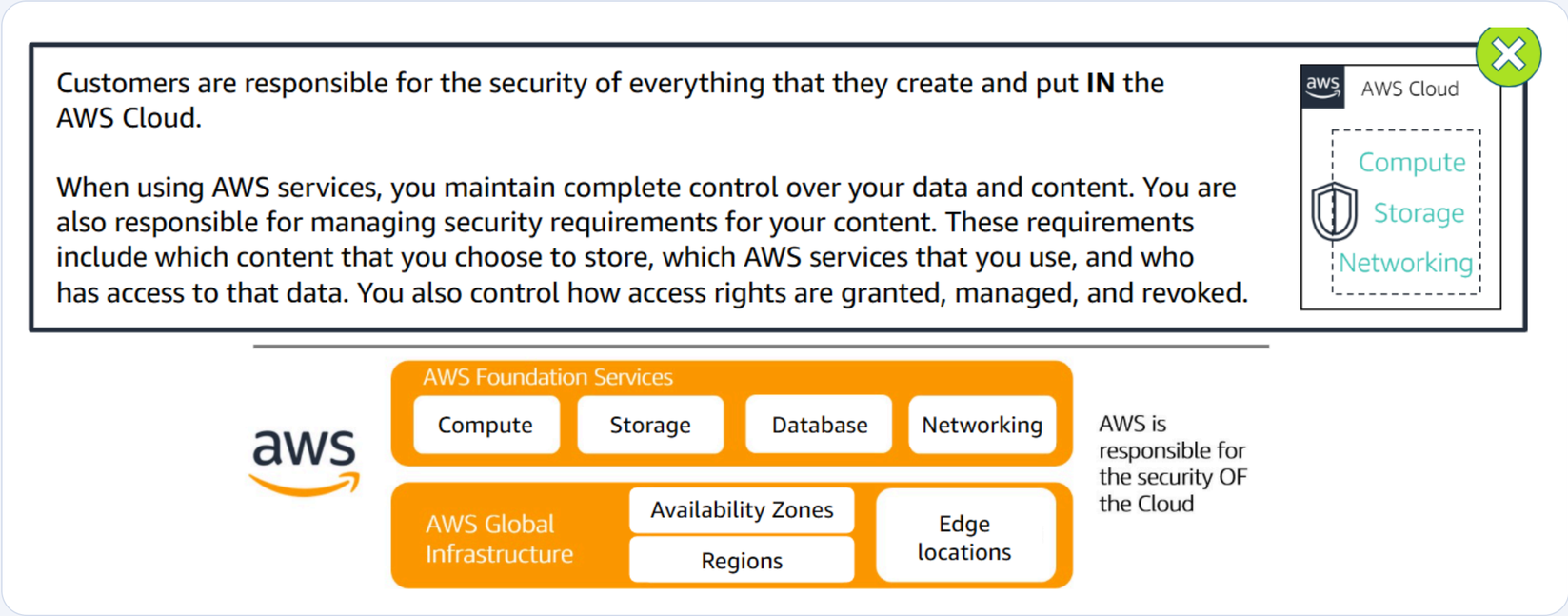
Shared responsibility model

Security is shared between AWS and the customer.

AWS shared responsibility model

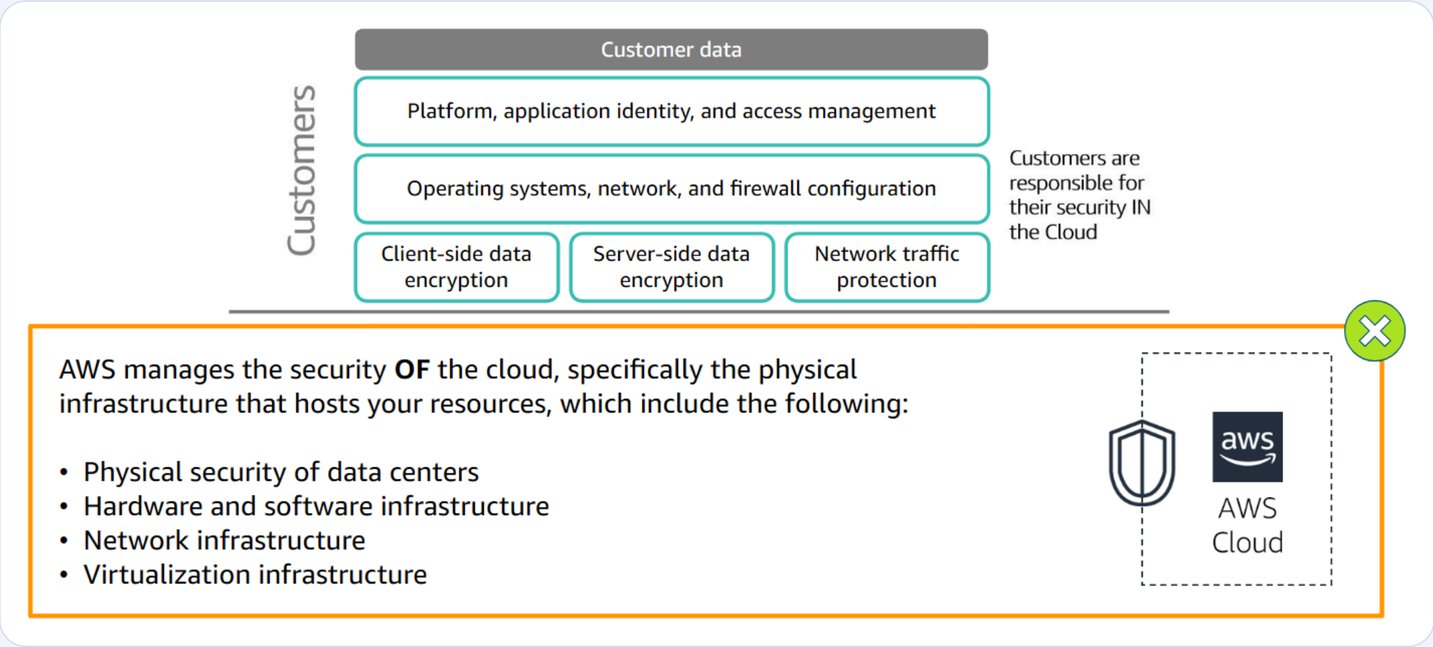


Shared responsibility: the customer



Security IN the cloud: you keep complete control of your content, and decide what to store, which services to use and who has access.

Shared responsibility: AWS



Security OF the cloud: datacenters, hardware and software infrastructure, network infrastructure and virtualization infrastructure.

Shared responsibility model examples

Responsibility	Amazon S3	Amazon EC2	Amazon VPC
Customer (security IN the cloud)	Bucket access policy. Data encryption. File delete protection (versioning and MFA). User access.	Patching the guest operating system. Security group configurations. Encrypting volumes. IAM instance profiles. User access.	Security group configurations. Network ACL configurations. Configuring for public or private access. User access.
AWS (security OF the cloud)	Protecting the infrastructure that runs the service.	Protecting the infrastructure that runs the service.	Protecting the infrastructure that runs the service.

For all three services, AWS protects the hardware, software, networking and physical facilities that run them.

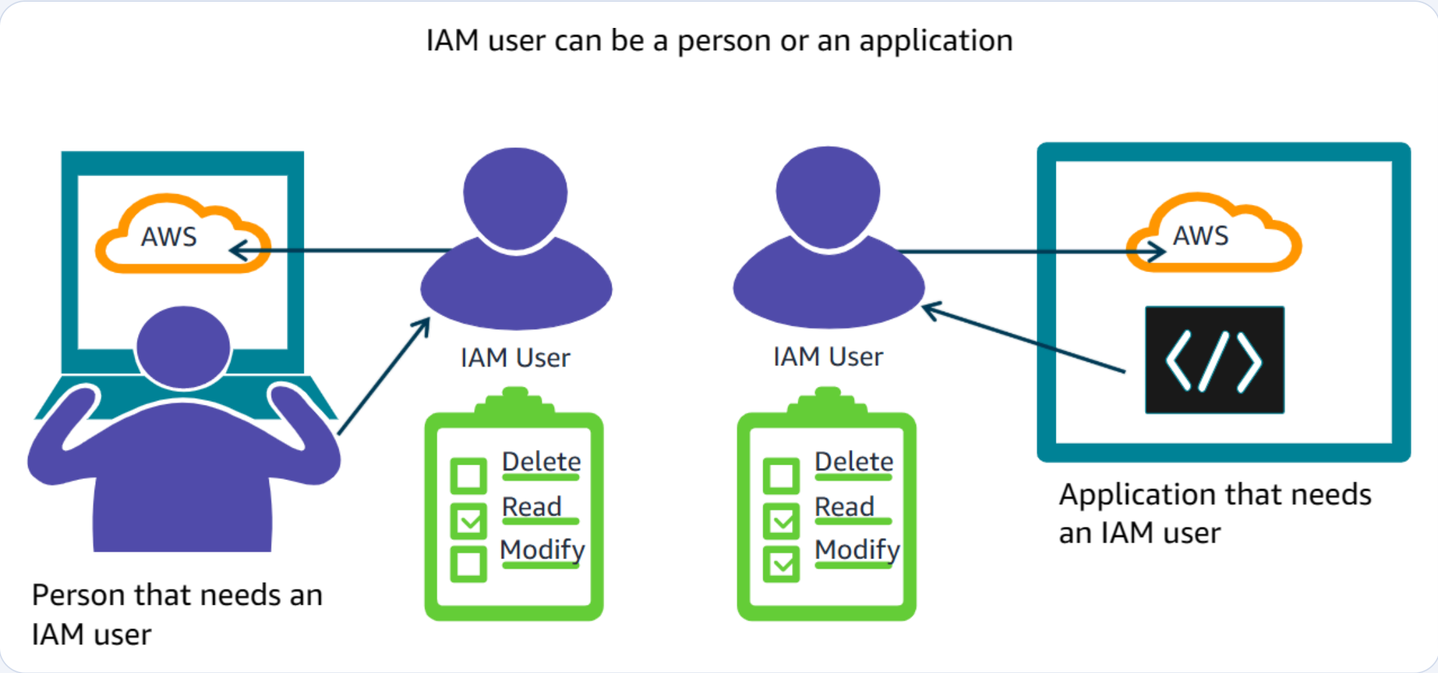
PART 4

AWS IAM

AWS Identity and Access Management: users, credentials, policies and the root user.

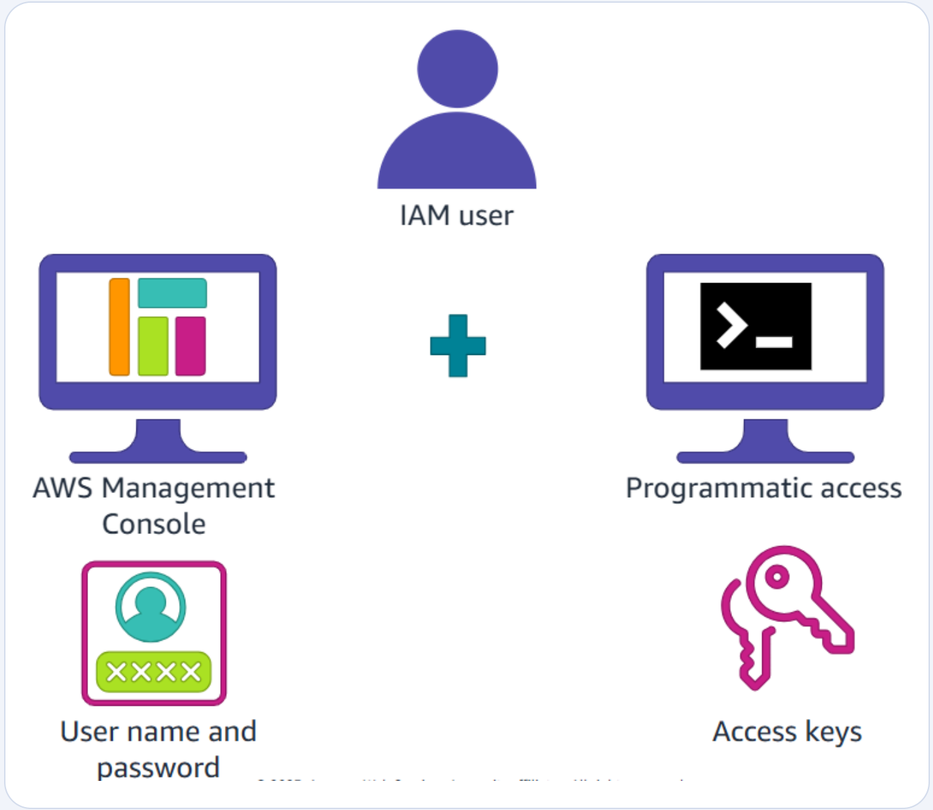
Week 10

Identity and Access Management users



An IAM user can be a person or an application. Each has its own permissions.

IAM credential types



IAM credential types: console password

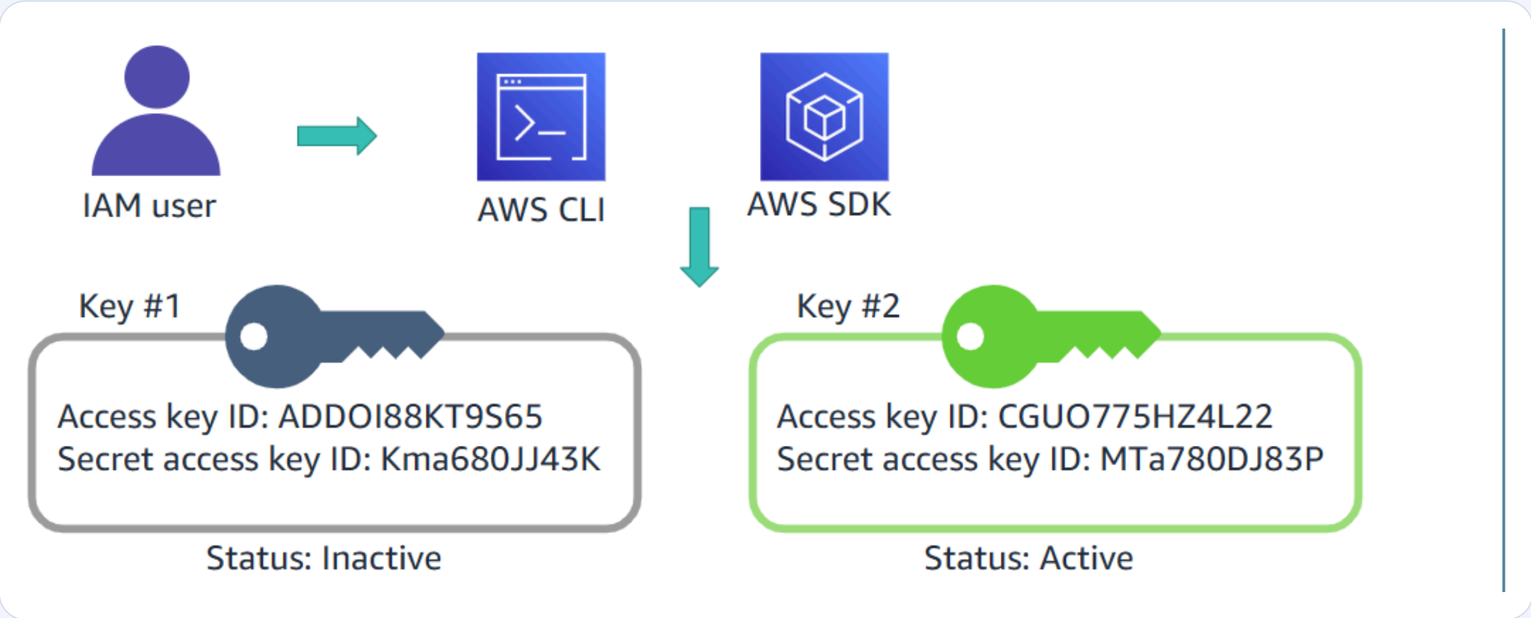
Users of the AWS Management Console sign in with a user name and password.

IAM lets you manage passwords with a password policy: a set of rules that define the type of password an IAM user can set. Define one for all of your IAM users, to enforce strong passwords and regular changes.

A password policy can

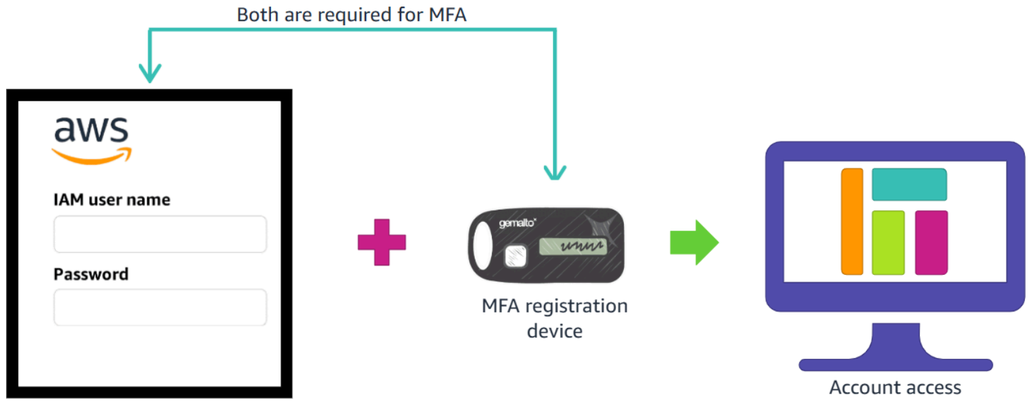
- Enforce a minimum password length
- Require uppercase, lowercase, number and non-alphanumeric characters
- Enable password expiration, with an administrator reset
- Let users change their own password
- Prevent password reuse

IAM credential types: access keys



For programmatic access through the AWS CLI, SDKs or HTTPS calls. Each key has an ID and a secret. A user can have two active keys, which helps when rotating them.

Multi-factor authentication (MFA)



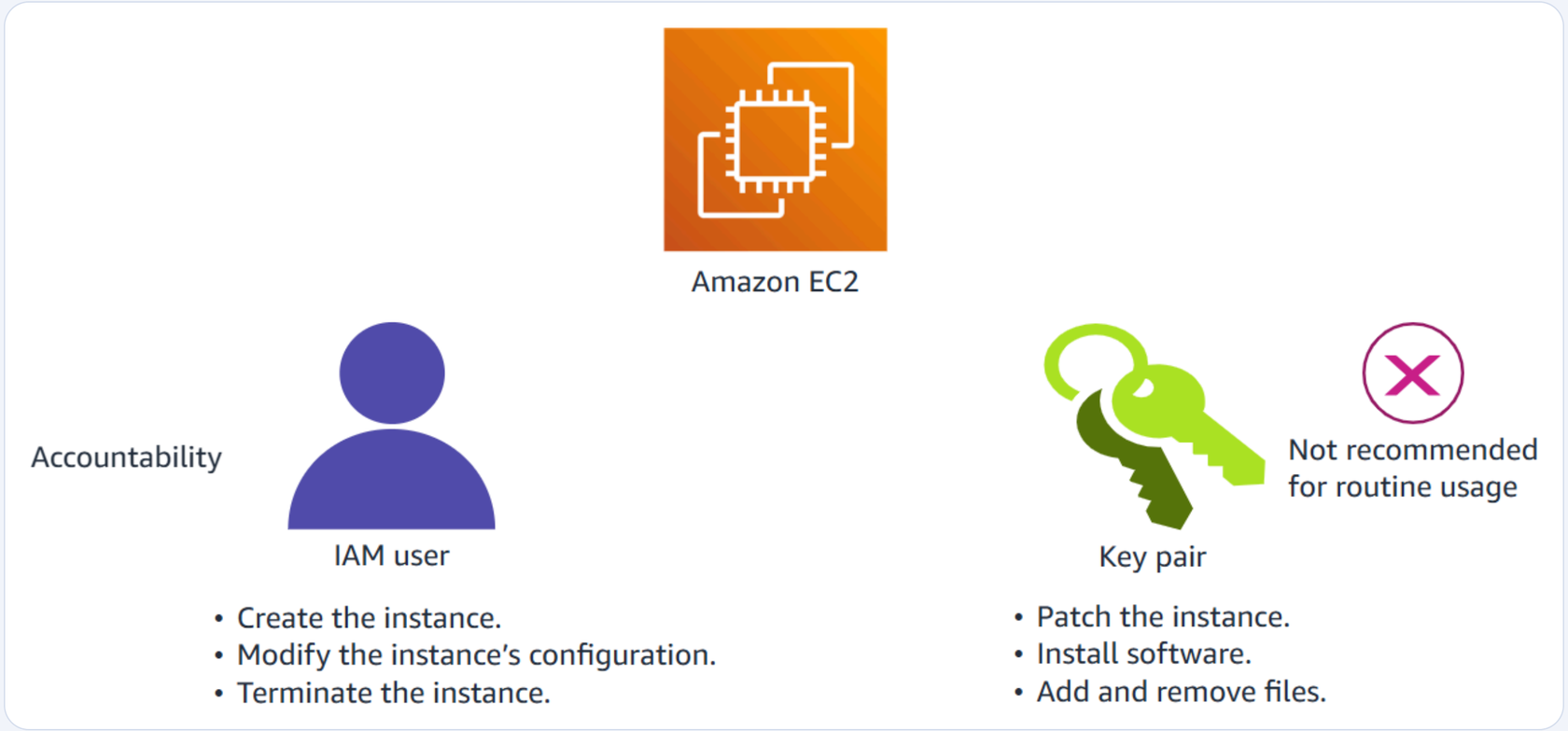
Console: both are required for MFA



AWS CLI: the device is required too

MFA adds a second proof of identity: something you know, plus a device you have.

IAM users and accountability



IAM Identity Center



IAM use cases

Apply fine-grained permissions

Create and apply permissions based on user attributes such as department, job role and team name, using attribute-based access control.

Manage per-account access

Manage per-account identities, and provide multi-account access and application assignments across AWS.

Establish organization-wide guardrails

Use service control policies to set permissions guardrails for IAM users and roles, and a data perimeter around your accounts.

Set, verify and right-size permissions

Refine policies on the journey toward least privilege, using cross-account findings as you go.

IAM costs

What does not cost money?

AWS IAM is a free service that you can use at no additional charge.

What costs money?

The services you use that IAM provides access to, and the actions it permits, for example creating an EC2 instance.

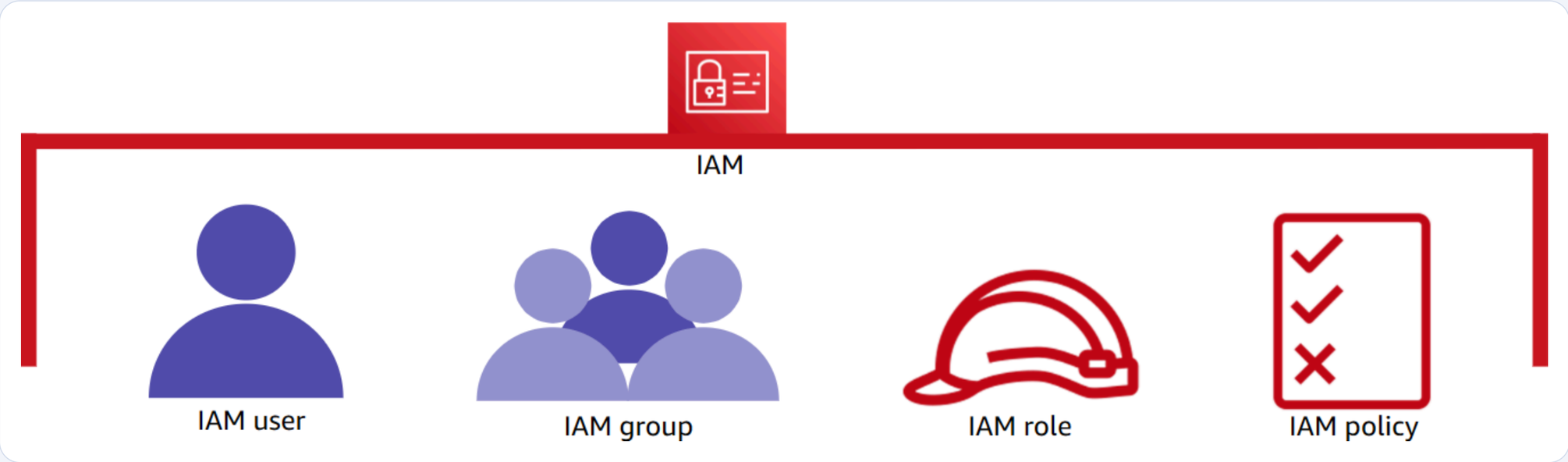
AWS Free Tier

AWS IAM is always free.

Estimate your own costs

The AWS Pricing Calculator helps you understand the costs of your own workload.

Options for using IAM



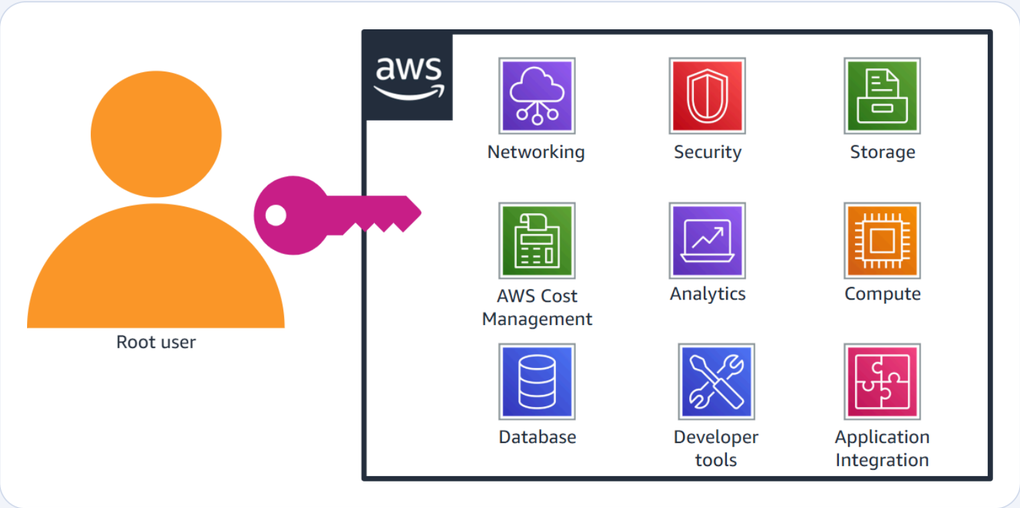
Create users, groups and roles, and a policy for each, through the AWS Management Console, the AWS CLI or the AWS SDK.

Root user

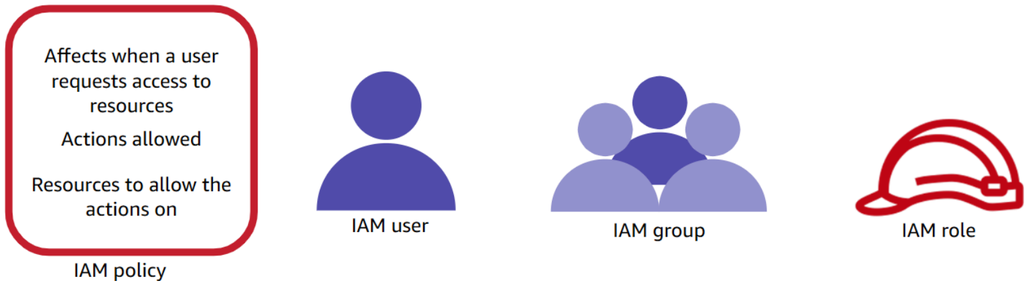
To ensure the safety of the root user:

- Choose a strong password.
- Enable multi-factor authentication for the root user.
- Never share the root user password or access keys.
- Disable or delete the root user's access keys.
- Create an IAM user with full access, except billing, for administrative tasks.

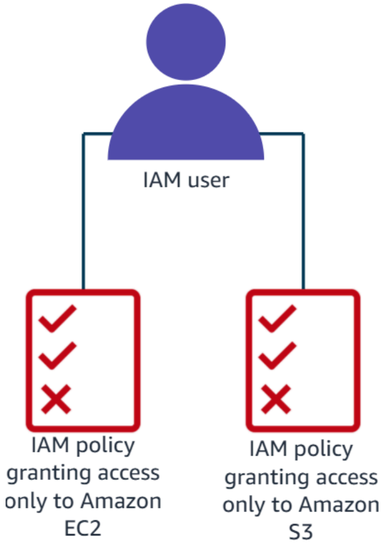
AWS strongly recommends that you do not use root account credentials for day-to-day interactions with AWS.



IAM policies



Actions allowed, on which resources



A user can have several policies

IAM policy example 1: single statement

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["DynamoDB:*", "s3:*"],
    "Resource": [
      "arn:aws:dynamodb:region:account-number-without-hyphens:table/table-name",
      "arn:aws:s3:::bucket-name",
      "arn:aws:s3:::bucket-name/*"]
  }]
}
```

One statement, three elements: Effect, Action and Resource.

IAM policy example 1: the elements

Effect

Required. Specifies whether the statement results in an allow or an explicit deny. Valid values are Allow and Deny. Here the Effect is Allow.

Action

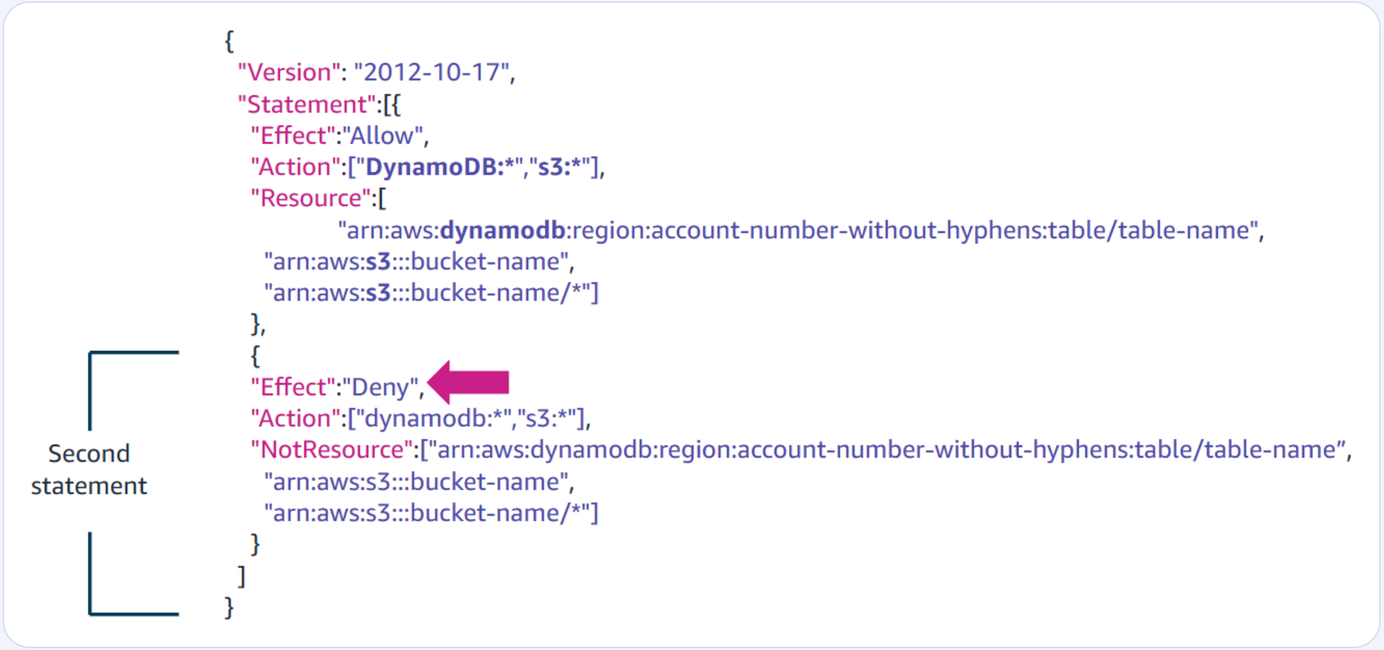
The specific action or actions that will be allowed or denied. A wildcard (*) gives access to all the actions a product offers. Here: any action on Amazon DynamoDB and Amazon S3.

Resource

The object or objects the statement covers, given as Amazon Resource Names (ARNs). Full control applies only to the ARNs listed, not to every resource.

Even with a wildcard in Action, the user reaches only the table and bucket named in Resource.

IAM policy example 2: multiple statements



The second statement uses Deny with NotResource: it explicitly denies the actions on every resource not listed.

Key takeaways

01

Permissions

Permissions give users the specific access to data and resources that their job role needs.

02

IAM tools

IAM tools are used to help govern user access and permissions.

03

Four layers

There are four main layers of security for protecting a datacenter.

04

Shared responsibility

AWS has a shared responsibility model that outlines the security responsibilities of AWS and the customer.

Next session



01

Cost management and economics